

ICS Protocols & Their Attacks

The Protocols: Built for Reliability, Not Security

Modbus	– industrial, 1979, no auth (anyone can read/write registers!)
BACnet	– building automation, minimal security
DNP3	– electric utilities, slightly safer, still limited
OPC-UA	– the modern face, encryption available, often skipped

The key truth: classic ICS protocols have **no authentication and no encryption** built in. Any host that can reach the network can command the controllers. "Security is assumed by isolation" – and convergence destroyed that assumption.

Modbus Deep-Dive (the textbook)

READ	Read Holding Registers (0x03) → attacker reads facility state
WRITE	Write Single/Multiple Registers → attacker CHANGES setpoints
FC	Force Coil (0x05) → flip a switch!

Even without Metasploit, a plain TCP packet is enough:

```
# READ registers 40001..40002 from a lab PLC-ish target (port 502):
python3 -c "
import struct, socket
s = socket.socket(); s.connect(('10.10.10.50', 502))
req = struct.pack('>12B', 0,0,0,6, 1, 3, 0,0,0,2,0,0) # FC03
s.send(req)
print('PLC response:', s.recv(64).hex())
"
```

The Attack Playbook Against ICS

Discovery → find controllers (they answer even without auth)

State disclosure → read registers: you learn everything

State manipulation → write registers: you affect the process

Denial of service → flood, lock, trigger e-stop

Persistence → a 'logic bomb' inside the PLC program itself (2014 Dragonfly pattern)

The Defense the Protocol Can't Give

Because plaintext PLC scanning 'just works', the real defense is architecture (IEC 62443):

DMZ ↔ OT zone ↔ cell/plant zones ↔ safety zones

Each boundary: firewall + active monitoring + no unsanctioned internet egress

IEC 62443 is THE standard for ICS security: zones, conduits, security levels (SL 1-4).

Monitoring the OT World

Log/alert on: communication beyond allowed pairs (PLC↔HMI↔SCADA server only)

Unusual time patterns (a register write at 3am)

Whitelist allowed Modbus/DNP3 function codes (crazy powerful)

Tripwire: a fingerprint of allowed read/write activity

The Stuxnet Case Re-read

Attacker needed no protocol exploit – Modbus-era trust meant it could just instruct the PLCs to destroy centrifuges. The lesson: don't wait for new malware; trust-chain abuse IS the attack.

In one sentence: ICS says 'operate' and security says 'every read AND write must be authenticated'. When the two collide, the architecture – not the protocol – must supply the missing trust.